

07 — Security Architecture

Purpose

The purpose of this document is to define the security architecture of Mosaica.

This module establishes the security principles, protection mechanisms and architectural boundaries required to protect:

- User identities,
- personal archive data,
- shared metadata,
- API communication,
- application resources.

The Security Architecture ensures that security requirements are integrated into the system design rather than added as a separate layer afterwards.

Security Architecture Scope

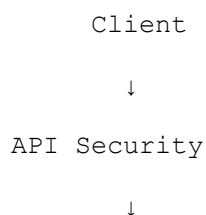
This module defines:

- security principles,
- identity management,
- access control,
- data protection,
- threat considerations,
- security validation processes.

The purpose is not to define implementation-specific security tools, but to establish architectural requirements.

Security Architecture Position

Security is a cross-cutting concern that applies across all Mosaica layers.



Application Authorization

↓

Domain Protection

↓

Data Protection

Security Responsibilities

API Layer

Responsible for:

- secure communication boundaries,
 - authentication enforcement,
 - request protection.
-

Application Layer

Responsible for:

- authorization decisions,
 - ownership verification,
 - secure workflow execution.
-

Domain Layer

Responsible for:

- business integrity,
 - valid state protection,
 - preventing invalid operations.
-

Persistence Layer

Responsible for:

- data integrity,
- secure storage,

- controlled access.
-

Security Architecture Principles

Principle 1 — Security By Design

Security requirements shall be considered during architectural decisions.

Security shall not be treated as a later implementation step.

Principle 2 — Least Privilege

Users and system components shall receive only the permissions required for their responsibilities.

Principle 3 — Ownership Protection

User-owned information shall only be accessible by authorized owners.

Principle 4 — Separation of Concerns

Security responsibilities shall be distributed across appropriate architectural layers.

No single layer shall become responsible for all security decisions.

Principle 5 — Defense in Depth

Mosaica shall use multiple protection layers.

A single security mechanism shall not be considered sufficient.

Security Context Model

Mosaica contains two primary security contexts.

Security Model

Shared Information

(Content Metadata)

↓

Accessible according to system permissions

Personal Information

(Library Experience)

↓

Protected by User Ownership

Protected Resources

Identity Resources

Examples:

- User account information,
 - authentication data.
-

Personal Archive Resources

Examples:

- Library Entries,
 - Ratings,
 - Notes,
 - Consumption History,
 - Collections,
 - Tags.
-

Shared Metadata Resources

Examples:

- Content,
 - Person,
 - Genre,
 - Series,
 - Universe.
-

Security Architecture Goals

The Security Architecture aims to provide:

- authenticated access,
 - authorized operations,
 - protected personal information,
 - reliable data integrity,
 - secure API communication,
 - controlled system evolution.
-

Module Structure

07 Security Architecture

07.01 Security Principles

07.02 Identity & Access Management

07.03 Data Protection

07.04 Threat Model

07.05 Security Architecture Review

Architectural Decisions Introduced

Decision 01

Security is treated as a cross-cutting architectural concern.

Decision 02

Personal archive data is protected primarily through ownership-based security.

Decision 03

Shared metadata and personal information require different protection models.

Decision 04

Security responsibilities are distributed across system layers.

07.01 — Security Principles

Purpose

The purpose of this section is to define the fundamental security principles that guide the design and evolution of the Mosaica system.

These principles establish the security foundation for:

- identity protection,
- authorization,
- data privacy,
- application integrity,
- future security decisions.

All security-related architectural decisions shall be evaluated against these principles.

Security Principles

Principle 1 — Security By Design

Definition

Security shall be considered during system design rather than added after implementation.

Security requirements shall influence architectural decisions from the beginning.

Application

Security considerations shall be included when designing:

- APIs,
- database structures,
- workflows,
- user permissions,
- data handling processes.

Principle 2 — Least Privilege

Definition

Every user and system component shall have only the permissions required to perform its responsibilities.

Additional access shall not be granted by default.

Application

Examples:

A User can:

- manage their own Library Entries,
- modify their own Collections,
- update their own Tags.

A User cannot:

- modify another User's archive,
- access private personal information,
- perform unauthorized system operations.

Principle 3 — Ownership-Based Protection

Definition

Personal data protection shall primarily follow ownership relationships.

Ownership determines who can access and modify personal resources.

Application

The following resources are protected through ownership:

- Library Entry,
 - Collection,
 - Tag,
 - Personal Note,
 - Consumption History.
-

Example

User A

owns

Library Entry A

User B

cannot access

Library Entry A

Principle 4 — Separation of Shared and Personal Data

Definition

Shared information and personal information shall remain separate security contexts.

Shared Context

Examples:

- Content,

- Person,
 - Genre,
 - Series,
 - Universe.
-

Personal Context

Examples:

- Rating,
 - Status,
 - Favorite,
 - Notes,
 - Consumption History.
-

Security Impact

A User may access shared Content information without gaining access to another User's personal experience.

Principle 5 — Defense in Depth

Definition

Security shall rely on multiple protection layers rather than a single mechanism.

Security Layers

Authentication

↓

Authorization

↓

Application Validation

↓

Domain Protection

↓

Database Integrity

Reason

A failure in one layer should not automatically compromise the entire system.

Principle 6 — Secure Failure

Definition

When security validation fails, the system shall fail safely.

Errors shall not reveal sensitive internal information.

Application

Security failures shall:

- deny unauthorized access,
 - provide controlled responses,
 - avoid exposing internal details.
-

Principle 7 — Data Minimization

Definition

The system shall store and expose only the data required for its purpose.

Application

Mosaica shall avoid:

- unnecessary personal data collection,
- excessive API exposure,
- redundant sensitive information storage.

Principle 8 — Auditability

Definition

Important security-related operations should be traceable.

Application

Future implementations should consider tracking:

- authentication events,
 - permission changes,
 - critical data modifications.
-

Principle 9 — Secure Evolution

Definition

Security architecture shall support future growth without requiring fundamental redesign.

Application

Future additions shall preserve:

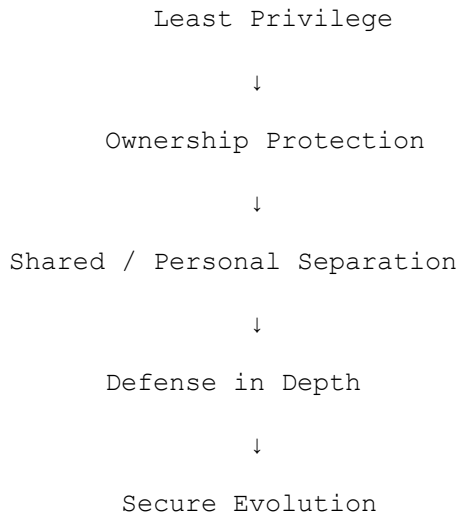
- ownership rules,
 - access boundaries,
 - data protection principles.
-

Security Principle Model

Mosaica Security

Security By Design

↓



Architectural Decisions Confirmed

Decision 01

Security is a foundational architectural concern.

Decision 02

Personal data protection is primarily ownership-based.

Decision 03

Shared metadata and personal archive data use different security approaches.

Decision 04

Security decisions must preserve existing Domain and Application boundaries.

Decision 05

Security failures must not expose sensitive internal information.

07.02 — Identity & Access Management

Purpose

The purpose of this section is to define the Identity and Access Management architecture of Mosaica.

This section establishes how Users are:

- identified,
- authenticated,
- authorized,
- granted access to system resources.

The objective is to ensure that every operation is performed within a controlled identity and permission context.

Identity & Access Management Principles

Principle 1 — Identity Before Access

Every protected operation shall begin with verified User identity.

The system shall determine who is making a request before evaluating permissions.

Principle 2 — Authentication and Authorization Separation

Authentication and authorization are separate security responsibilities.

Authentication establishes identity.

Authorization determines permitted actions.

Principle 3 — Ownership-Based Authorization

Personal resources shall primarily be protected through ownership verification.

A User may access only resources belonging to that User.

Principle 4 — Default Denial

Access shall be denied unless the User has sufficient permission to perform the requested operation.

Identity Model

The Mosaica identity model contains three primary concepts.

User Identity

↓

Authentication Context

↓

Authorization Decision

User Identity

Responsibility

Represents the authenticated person using the system.

Identity Information Includes

Examples:

- User identifier,
 - account information,
 - authentication-related information.
-

Identity Does Not Include

User identity shall not directly contain:

- Library Entries,
- Collections,
- Tags,
- Personal Notes.

These remain separate domain concepts.

Authentication Architecture

Purpose

Authentication verifies User identity.

Authentication Flow

User

↓

Authentication Request

↓

Identity Verification

↓

Authentication Result

↓

Authenticated Context

Authentication Context

After successful authentication, the system creates an authenticated context.

This context provides:

- current User identity,
 - request authorization information,
 - security context.
-

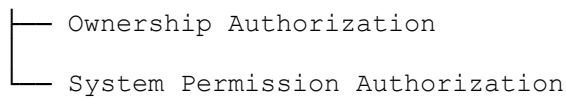
Authorization Architecture

Authorization determines whether an authenticated User may perform an action.

Authorization Model

Mosaica uses two primary authorization models.

Authorization



Ownership Authorization

Purpose

Protects User-owned resources.

Protected Resources

Examples:

- Library Entry,
 - Collection,
 - Tag,
 - Personal Note,
 - Consumption History.
-

Rule

A User may access or modify a resource only if ownership conditions are satisfied.

Example:

Authenticated User ID

=

System Permission Authorization

Purpose

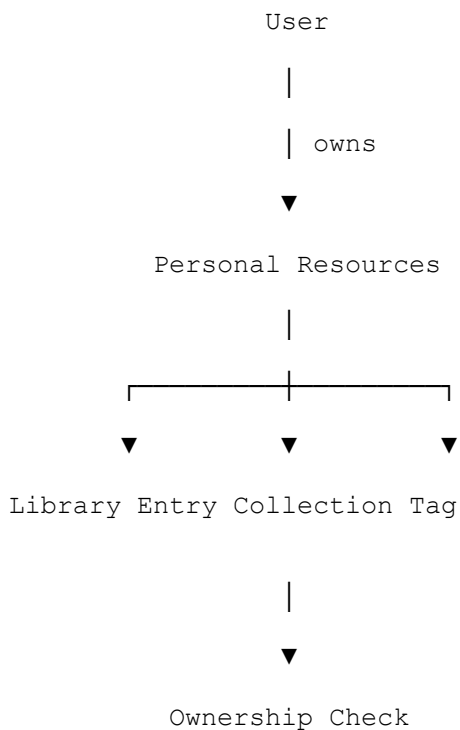
Controls operations that are not based on personal ownership.

Examples

Shared metadata operations:

- Content management,
 - administrative actions,
 - system-level operations.
-

Resource Access Model



Authentication Flow Example

Access Personal Library

Request:

GET /library-entries

Flow:

Request

↓

Authenticate User

↓

Create User Context

↓

Load User Library

↓

Return Personal Data

Authorization Flow Example

Update Library Status

Request:

PATCH /library-entries/{id}/status

Flow:

Authenticate User

↓

Find Library Entry

↓

Check Ownership

↓

Execute Domain Operation

↓

Save Changes

Role Model

At Version 1, Mosaica uses a simplified authorization model.

User Role

Default system role.

Responsible for personal operations.

Administrative Roles

Future roles may be introduced if system requirements require them.

They are intentionally not defined in Version 1.

Security Boundaries

The following boundaries are established.

Boundary 1

Authentication does not grant ownership.

A logged-in User must still pass authorization checks.

Boundary 2

Access to one User's personal data never grants access to another User's data.

Boundary 3

Shared Content access does not expose personal Library information.

Boundary 4

Application Services are responsible for coordinating authorization checks.

Identity & Access Model

Client Request



Authentication



User Identity



Authorization



Application Service



Domain Operation

Architectural Decisions Confirmed

Decision 01

Authentication establishes identity.

Decision 02

Authorization determines allowed actions.

Decision 03

Personal resources are protected through ownership verification.

Decision 04

Default access behavior is denial unless permission is granted.

Decision 05

Version 1 uses a simple User-based authorization model.

07.03 — Data Protection

Purpose

The purpose of this section is to define the data protection architecture of Mosaica.

This section establishes how system data is protected throughout its lifecycle, including:

- data storage,
- data access,
- data transmission,
- data exposure,
- data lifecycle management.

The objective is to ensure that both shared metadata and User-owned personal information remain protected according to their business importance.

Data Protection Principles

Principle 1 — Data Classification

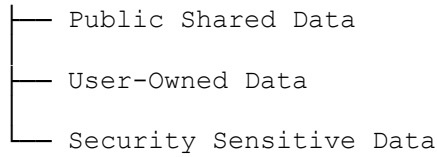
Data shall be classified according to its sensitivity and ownership.

Different data categories shall receive appropriate protection levels.

Data Classification Model

Mosaica data is divided into three primary categories.

Data Classification



Public Shared Data

Definition

Information that represents shared cultural metadata.

Examples

- Content information,
 - Person information,
 - Genre information,
 - Series information,
 - Universe information.
-

Protection Approach

This data requires:

- integrity protection,
- controlled modification,
- reliable storage.

It does not require User ownership protection.

User-Owned Data

Definition

Information created through a User's personal interaction with the system.

Examples

- Library Entries,
 - Ratings,
 - Status,
 - Favorites,
 - Personal Notes,
 - Consumption History,
 - Collections,
 - Tags.
-

Protection Approach

This data requires:

- ownership protection,
 - access control,
 - privacy preservation.
-

Security Sensitive Data

Definition

Information related to system security and identity management.

Examples

- Authentication information,
 - Security credentials,
 - Access-related information.
-

Protection Approach

This data requires:

- restricted access,
- secure storage,
- controlled exposure.

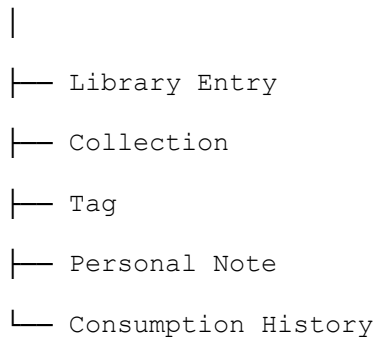
Data Ownership Protection

Principle

Every User-owned resource shall have a clear ownership boundary.

Ownership Model

User



Protection Rule

A User-owned resource shall only be accessible through an authorized User context.

Data Exposure Principles

Principle 1 — Minimum Necessary Exposure

The system shall expose only the data required for a specific operation.

Application

API responses shall not include unnecessary:

- internal identifiers,
- security information,
- private User data.

Principle 2 — Context-Based Data Access

Data exposure depends on context.

Example:

Content API:

```
GET /contents/{id}
```

↓

Returns:

```
Title  
Media Type  
Metadata
```

Does not return:

```
User Rating  
Personal Note  
Consumption History
```

Library API:

```
GET /library-entries/{id}
```

↓

Returns:

```
Personal Experience Data
```

Data Storage Protection

Principle

Stored data shall preserve confidentiality and integrity.

Requirements

The persistence layer shall support:

- controlled access,
 - integrity validation,
 - secure backup strategies,
 - protection against unauthorized modification.
-

Personal Data Isolation

Principle

Personal data shall remain isolated from shared metadata.

Example

Incorrect:

```
contents
- title
- genre
- user_rating
- personal_note
```

Correct:

```
contents
- title
- genre

library_entries
- user_rating
- personal_note
```

Data Lifecycle Protection

Data shall be protected throughout its lifecycle.

Creation

↓

Storage

↓

Access

↓

Modification

↓

Deletion

Data Modification Protection

Important personal changes shall occur through controlled application workflows.

Direct database modification shall not bypass:

- authorization,
 - validation,
 - domain rules.
-

Data Deletion Principles

Deletion operations shall respect ownership and integrity.

Examples:

Collection Deletion

Allowed:

Delete Collection

↓

Remove Collection Relationships

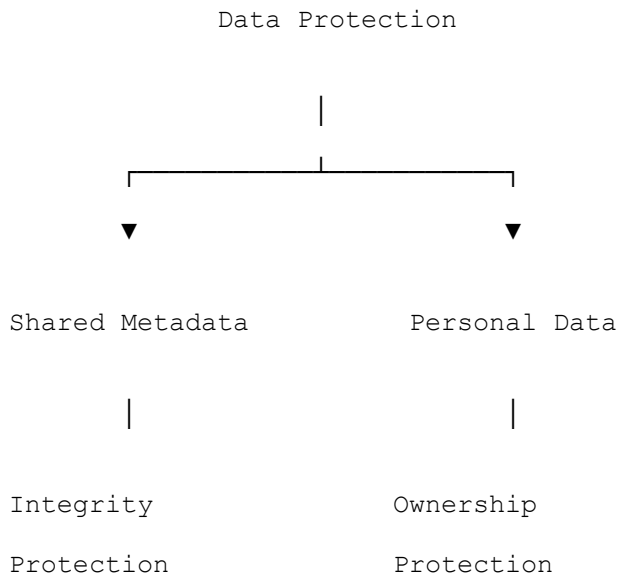
↓

Preserve Library Entries

Library Entry Deletion

Requires controlled handling because it contains personal history.

Data Protection Model



Architectural Decisions Confirmed

Decision 01

Data protection follows ownership and sensitivity classification.

Decision 02

Shared metadata and personal data remain physically and logically separated.

Decision 03

Personal information is protected through ownership-based access.

Decision 04

API exposure follows minimum necessary data principles.

Decision 05

Data changes must pass through authorized application workflows.

07.04 — Threat Model

Purpose

The purpose of this section is to define the security threat model of Mosaica.

This section identifies potential security risks that may affect:

- User identity,
- personal archive data,
- shared metadata,
- API communication,
- system integrity.

The objective is to establish security priorities and ensure that architectural decisions address realistic threats.

Threat Modeling Principles

Principle 1 — Risk-Based Security

Security efforts shall focus on realistic threats that may impact system users, data and operations.

Principle 2 — Protect Critical Assets First

Security decisions shall prioritize the protection of the most valuable resources.

Principle 3 — Prevention and Detection

The system shall consider both:

- preventing unauthorized actions,
 - detecting security-related events.
-

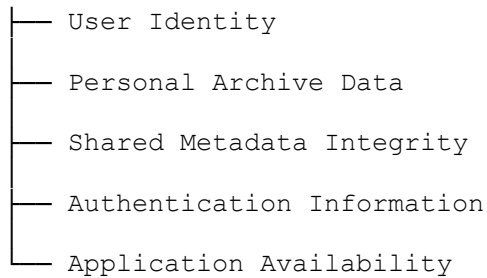
Principle 4 — Continuous Improvement

Threat analysis shall evolve as Mosaica gains new capabilities and features.

Protected Assets

The primary assets requiring protection are:

Mosaica Assets



Asset 1 — User Identity

Description

Information used to identify and authenticate Users.

Security Importance

Compromised identity may allow unauthorized access to personal resources.

Protection Requirements

Requires:

- secure authentication,

- controlled access,
 - identity verification.
-

Asset 2 — Personal Archive Data

Description

User-owned information representing personal interaction with Content.

Examples

- Library Entries,
 - Ratings,
 - Notes,
 - Consumption History,
 - Collections,
 - Tags.
-

Security Importance

This data represents private User experience.

Protection Requirements

Requires:

- ownership validation,
 - authorization checks,
 - controlled exposure.
-

Asset 3 — Shared Metadata Integrity

Description

Shared cultural information used by multiple Users.

Examples

- Content information,
- Person information,
- Classification data.

Security Importance

Incorrect modification may affect many Users.

Protection Requirements

Requires:

- modification control,
- integrity validation,
- controlled management.

Asset 4 — Authentication Information

Description

Information required to verify User identity.

Security Importance

Compromise may result in account takeover.

Protection Requirements

Requires:

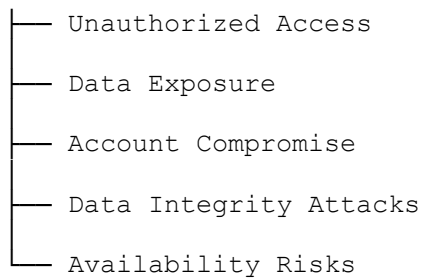
- secure storage,
- restricted access,

- careful handling.

Threat Categories

Mosaica threats are grouped into five main categories.

Threat Model



Threat 1 — Unauthorized Access

Description

A person accesses resources without proper permission.

Example

A User attempts to access another User's Library Entry.

Impact

Potential exposure of personal information.

Mitigation Principles

- Authentication,
- Authorization,
- Ownership verification.

Threat 2 — Data Exposure

Description

Private information becomes visible to unauthorized parties.

Example

Personal Notes appearing in shared Content responses.

Impact

Loss of User privacy.

Mitigation Principles

- Data separation,
 - DTO control,
 - Minimum data exposure.
-

Threat 3 — Account Compromise

Description

An attacker gains control of a User account.

Example

Unauthorized login using stolen credentials.

Impact

Access to personal archive data.

Mitigation Principles

- Secure authentication,
 - identity protection,
 - session security.
-

Threat 4 — Data Integrity Attack

Description

Unauthorized modification of system data.

Examples

- Changing Content metadata incorrectly.
 - Modifying another User's archive information.
-

Impact

Loss of data reliability.

Mitigation Principles

- Domain validation,
 - controlled workflows,
 - authorization checks.
-

Threat 5 — Availability Risks

Description

The system becomes unavailable or unusable.

Examples

- excessive requests,
 - infrastructure failures,
 - service disruption.
-

Impact

Users cannot access Mosaica services.

Mitigation Principles

- resilient architecture,
 - monitoring,
 - scalable infrastructure.
-

Threat and Mitigation Matrix

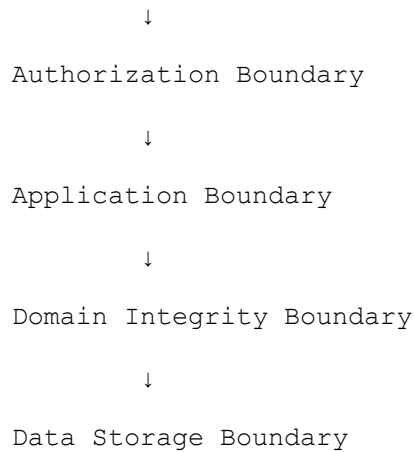
Threat	Impact	Primary Protection
Unauthorized Access	Private data exposure	Authentication + Authorization
Data Exposure	Privacy loss	Data separation + API control
Account Compromise	Account takeover	Identity protection
Data Integrity Attack	Incorrect information	Domain validation
Availability Risk	Service interruption	Resilience planning

Security Boundary Model

External User

↓

Authentication Boundary



Future Security Considerations

The following areas may require additional security design as the system evolves:

- advanced role management,
- external integrations,
- public sharing features,
- collaboration features,
- third-party services.

These features shall require separate security evaluation before implementation.

Architectural Decisions Confirmed

Decision 01

Threat analysis focuses on protecting critical system assets.

Decision 02

Personal archive data is considered a high-priority protected resource.

Decision 03

Ownership and authorization are primary defenses against unauthorized access.

Decision 04

Data integrity is protected through controlled application workflows.

Decision 05

Future features require security evaluation before introduction.

07.05 — Security Architecture Review

Review Objective

The purpose of this Architecture Review is to validate that the Mosaica Security Architecture provides an appropriate security foundation while preserving the approved system architecture.

This review confirms that security decisions are aligned with:

- Domain Model,
- Database Specification,
- API Specification,
- Application Architecture.

The review ensures that security mechanisms protect the system without introducing unnecessary complexity.

Scope Reviewed

The following security architecture components have been reviewed:

- Security Principles
 - Identity & Access Management
 - Data Protection
 - Threat Model
-

Validation Results

Security Architecture Alignment

Status: Approved

The Security Architecture is consistent with the previously approved architectural layers.

Security responsibilities are correctly distributed across:

- API Layer,
- Application Layer,
- Domain Layer,
- Persistence Layer.

Identity Management

Status: Approved

The identity model correctly separates:

- User identification,
- authentication,
- authorization.

The architecture does not assume that authentication alone grants access.

Access Control

Status: Approved

Authorization rules correctly follow ownership boundaries.

Confirmed:

- Users manage their own Library Entries.
 - Users manage their own Collections.
 - Users manage their own Tags.
 - Users cannot access other Users' personal information.
-

Shared and Personal Data Protection

Status: Approved

The security architecture correctly preserves the separation between:

Shared Data

Examples:

- Content,
- Person,
- Genre,
- Series,
- Universe.

Personal Data

Examples:

- Ratings,
- Status,
- Favorites,
- Notes,
- Consumption History.

Data Protection Strategy

Status: Approved

The data protection approach follows:

- minimum exposure,
- ownership protection,
- controlled modification,
- secure data handling.

The architecture avoids exposing unnecessary internal information.

Threat Model Evaluation

Status: Approved

The identified threats correctly represent the primary security risks of Mosaica.

The main protected assets are:

- User identity,
 - Personal archive data,
 - Shared metadata integrity,
 - Authentication information.
-

Complexity Evaluation

Status: Approved

The security architecture avoids unnecessary complexity.

The following decisions are intentionally deferred:

- advanced role systems,
- enterprise permission models,
- complex collaboration security.

These features shall only be introduced when required by future product needs.

Architectural Decisions Confirmed

Decision 01

Security is a cross-cutting architectural concern.

Decision 02

Authentication and authorization remain separate responsibilities.

Decision 03

Personal resources are protected primarily through ownership rules.

Decision 04

Shared metadata and personal data require different security approaches.

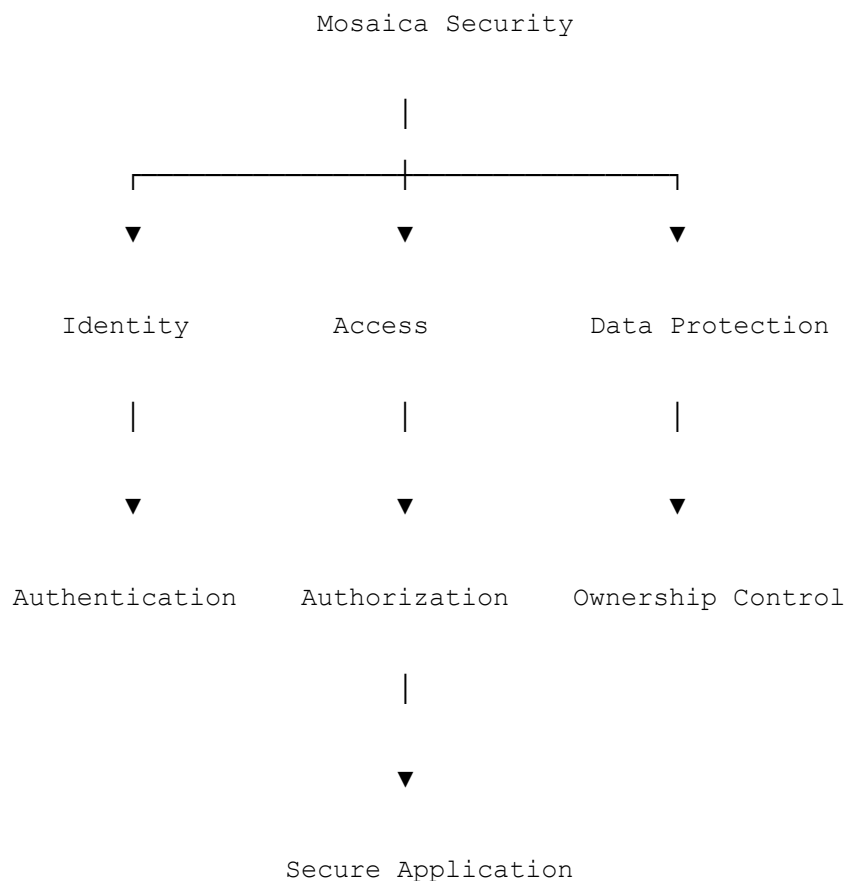
Decision 05

Security mechanisms shall protect the system without violating existing Domain boundaries.

Decision 06

Future security complexity requires explicit architectural evaluation.

Security Architecture Summary



Review Conclusion

The Mosaica Security Architecture is considered architecturally complete.

The current design provides a balanced security foundation that protects:

- User identity,
- personal information,
- shared system data,
- application integrity.

The architecture remains compatible with future expansion while avoiding unnecessary security complexity.

No blocking architectural issues have been identified.